

Auditable Session Admission for Cross-Silo Federated Learning

Core message

Admission control in cross-silo FL is not just plumbing:
it is the boundary mechanism that makes session
participation portable, auditable, and defensible across
organizations.

Enzo Fenoglio · Philip Treleaven
University College London

FLICS accepted paper

20 min talk · technical focus



Where cross-silo FL deployments get stuck

What FL already solves

Raw data stays local.
Model training is coordinated across organizations.
Privacy / locality constraints motivate adoption.

What still blocks deployment

Who may join?
Who may fetch, submit, evaluate, or end a session?
Which decisions remain justifiable after the run?

Paper's claim

The bottleneck is admission at the session interface, especially across heterogeneous org boundaries and regulated settings.

Adoption story $\neq$ deployment story

Important distinction: session admission is not local IAM

Session admission = “passport”

Cross-boundary decision to enter and invoke session-scoped operations for one specific session.

Concerned with shared approvals, session_id binding, and auditable evidence.

In-session authorization = “badge”

Organization-local IAM once inside: RBAC/ABAC, service authorization, internal data controls, infrastructure permissions.

Do not replace local IAM

Add a shared admission substrate at the boundary

Why existing IAM / policy plumbing is insufficient

Non-portable

Each organization has different identity stacks, policies, and deployment tooling. Integration becomes bespoke.

Hard to audit

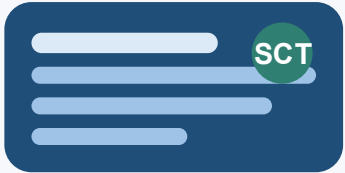
Decision logic is scattered across configuration, services, and orchestration code, so post hoc justification is difficult.

Brittle under drift

Operational changes can silently change effective admission behaviour without durable run-tied evidence.

The paper does not reject IAM. It says IAM alone does not define portable, session-scoped admission semantics with boundary-verifiable evidence.

Proposal: make every session request proof-carrying



1 Signed Session Capability Token

(SCT)

Enumerates permitted operations for one session_id and one holder.



2 Request-bound Proof of Possession (PoP)

Shows the caller controls the holder key for this exact request, making stolen tokens insufficient on their own.

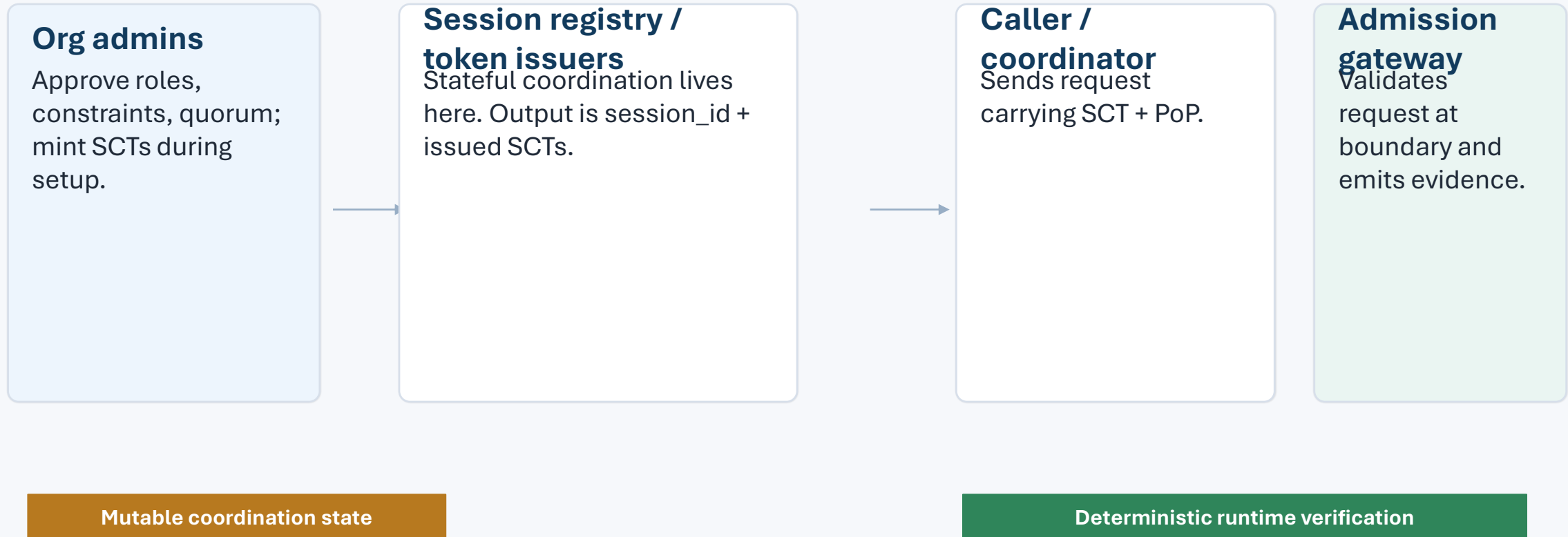
Gateway result

Stateless per-request cryptographic verification + capability matching at the session boundary.

Output

ALLOW / DENY + structured evidence record

Architecture split: stateful setup, stateless runtime admission



What an SCT carries

Core claims

session_id
issuer
sub
cnf.jkt
capabilities
constraints
exp

Why these fields matter

- session_id binds permission to one run
- sub identifies the holder in the issuing organization
- cnf.jkt binds the token to the holder public key
- capabilities define allowed abstract operations
- constraints limit time / rounds / rates / windows

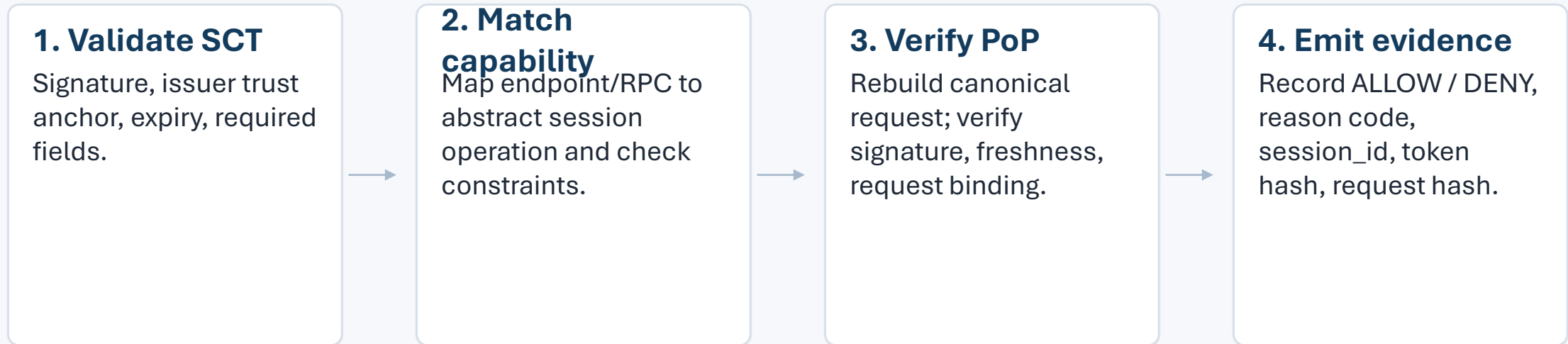
Realization

JOSE / JWT / JWS / JWK are a practical standard realization.

Design point

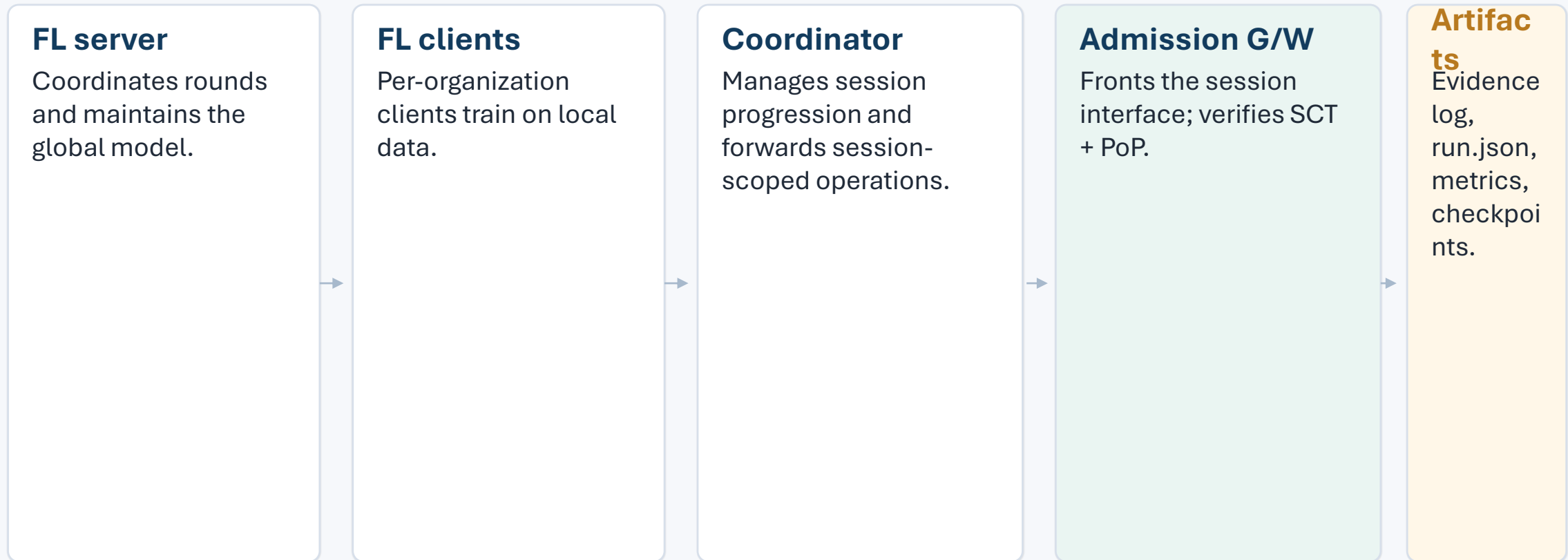
Format-agnostic abstraction; standards are used, not reinvented.

Admission is a four-step verification pipeline



Key property: the gateway relies on request-carried evidence and configured trust anchors, not on a central runtime policy service.

Prototype: Flower workflow plus an admission gateway



Workload: MNIST as a surrogate workload to exercise admission decisions, not to claim novel model-quality results.

What the evaluation demonstrates

Positive path

Valid SCT + valid PoP + permitted capability
→ ALLOW
→ request reaches the session interface
→ training proceeds and artifacts are produced.

Negative case 1

Capability mismatch
(e.g. evaluate requested but omitted from SCT)
→ DENY with explicit reason code.

Negative case 2

PoP mismatch / replay / stale proof
→ DENY before capability execution
→ stolen token alone is not enough.

The technical value is explicit, localizable failure handling at the boundary rather than hidden behaviour inside orchestration code.

Admission overhead is sub-millisecond in the prototype

Operation	ALLOW [ms]	DENY-Cap [ms]	DENY-PoP [ms]
Token verify	0.126	0.125	0.124
PoP verify	0.094	0.095	0.124
Capability match	0.003	0.003	N/A
Full admission check	0.261	0.261	0.255

Microbenchmark: median over n = 1000 requests on a single host, no concurrent load.

Interpretation

End-to-end admission is dominated by cryptographic verification. Capability matching is negligible. The PoP-mismatch path short-circuits, but total latency remains similar because signature checks dominate.

Why this matters for FL

The mechanism sits on session-interface RPCs, not on local training compute; it is unlikely to materially perturb the learning critical path.

What this work does not claim

Not a privacy/robustness paper

Secure aggregation, differential privacy, and malicious update defences are complementary and explicitly out of scope.

Not a full revocation study

Short-lived SCTs and rotation help, but mid-session revocation and compromise recovery are future operational hardening work.

Not vertical FL

Prototype targets cross-silo horizontal FL where organizations already hold local datasets.

Not a scale benchmark

Performance section is a sanity check, not a production throughput or tail-latency study.

Take-away for the FL community

If cross-silo FL is going to work operationally, we need a first-class session-boundary admission layer.

Portable

Admission semantics travel across heterogeneous organizations.

Verifiable

Each request can be checked from evidence visible at the boundary.

Auditable

Decision records remain explainable after the run.

Admission control is part of FL system design, not post hoc plumbing.

Questions